

SHADOWFOX

Cybersecurity Internship Program

CYBERSECURITY INTERN REPORT

Beginner & Intermediate & Advanced Level Tasks

Field	Details
Name	OGARA RAHMATU IZE
Program ID	SF-PID-2026-W2126
Batch	April B1 Cybersecurity
Gmail	izeogara@gmail.com
Institution	National Institute of Information and Technology
Domain	Cyber Security
Task Level	Beginner & Intermediate Level & Advanced level
Date	April 2026

Table of Contents for beginner and intermediate level

S.No	Title	Section
1	Introduction	3
2	Scope and Objectives	3
3	Tools Used	3
4	BEGINNER LEVEL TASKS	
4.1	Task 1 - Port Scanning (Find open ports on http://testasp.vulnweb.com/)	4
4.2	Task 2 - Directory Brute Forcing	5
4.3	Task 3 - Network Traffic Interception (Wireshark)	6
5	INTERMEDIATE LEVEL TASKS	
5.1	Intermediate Task 1 - VeraCrypt Hash Decryption	7
5.2	Intermediate Task 2 - PE Executable Entry Point Analysis	8
6	Overall Impact and Risk Summary	9
7	Recommendations	9
8	Conclusion	9

1. Introduction

In the domain of cybersecurity, understanding and detecting vulnerabilities in web applications is critical to protecting systems against potential cyber threats. During this internship at ShadowFox, I was assigned the task of conducting a comprehensive security evaluation on the following target website:

<http://testasp.vulnweb.com/>

This website is an intentionally vulnerable web application built using ASP, designed as a testing environment for security professionals. The purpose of this report is to document the penetration testing process, findings, and recommendations for improving the security posture of the target application.

2. Scope and Objectives

The scope of this assessment covers the following activities:

- Port Scanning - Identify all open ports and services running on the target web server
- Directory Brute Forcing - Discover hidden directories and files on the target website
- Network Traffic Interception - Capture and analyze login credentials transmitted over the network
- VeraCrypt Hash Decryption - Decode a hash-encoded password and decrypt an encrypted file
- Executable Entry Point Analysis - Identify the entry point of a PE executable using PEvent

All testing was performed in a controlled environment using Kali Linux within a VirtualBox virtual machine on a Windows 11 host. All activities were conducted on intentionally vulnerable targets designated for educational purposes.

3. Tools Used

Tool	Purpose	Platform
Nmap	Network port scanning and service detection	Kali Linux
Gobuster	Directory and file brute forcing	Kali Linux
Wireshark	Network packet capture and analysis	Kali Linux
Firefox Browser	Web browsing and login simulation	Kali Linux

VeraCrypt	Disk encryption/decryption tool	Windows 11
PEview	PE executable analysis	Windows 11
MD5Decrypt.net	Online MD5 hash decryption tool	Web Browser
Ping	Target IP address identification	Kali Linux

TASK LEVEL (BEGINNER)

4.1 Task 1 - Port Scanning

Find all the ports that are open on the website <http://testasp.vulnweb.com/>

Attack Name: Port Scanning

Severity: High - CVSS Score 7.0 to 8.9

Reason:

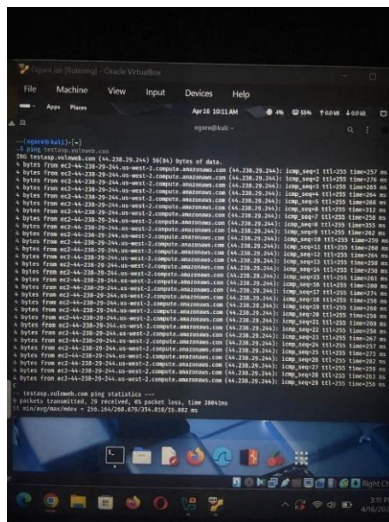
HTTP port 80 is considered highly severe because it is unencrypted, making it extremely susceptible to eavesdropping and data interception by malicious actors. This vulnerability can expose sensitive information, such as login credentials and credit card details, when used for web browsing.

Step 1: Target IP Identification

The website's IP address was identified using the ping command, which served as a precursor to the port scanning process.

Command used: ping testasp.vulnweb.com

Result: Target IP Address resolved to 44.238.29.244



```
Microsoft Windows [Version 10.0.17134.470] (c) 2018 Microsoft Corporation. All rights reserved.
C:\Users\user>ping testasp.vulnweb.com

Pinging testasp.vulnweb.com [44.238.29.244] with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 44.238.29.244:
    Packets: Sent = 10, Received = 0, Lost = 10 (100% loss),
    approx. round trip time = 1000 ms
```

Step 2: Port Scanning Using Nmap

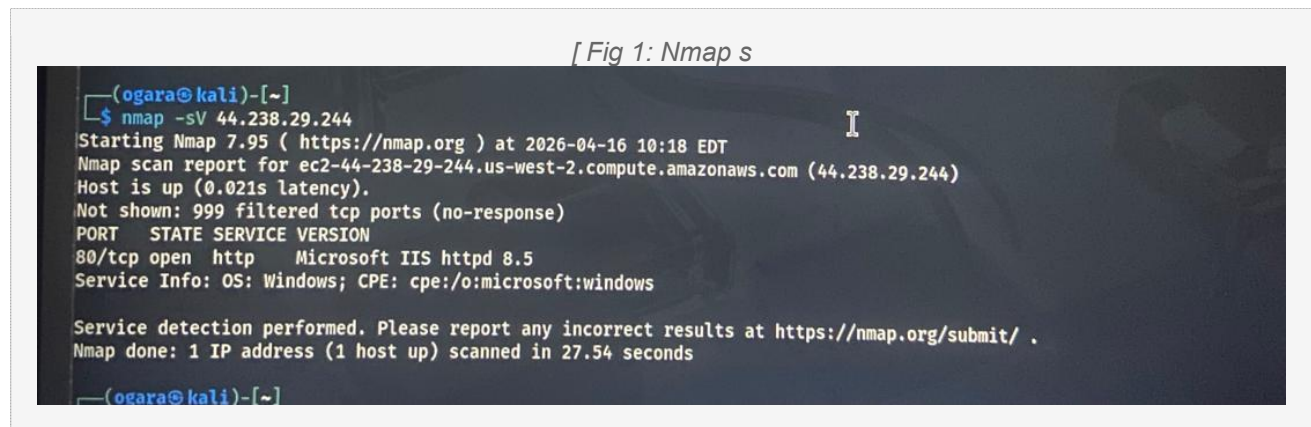
Using Nmap, a powerful network scanning tool, a port scan was conducted on the identified IP address.

Command used: nmap -sV 44.238.29.244

Scan Results:

Port/Protocol	State	Service	Version
80/tcp	Open	HTTP	Microsoft IIS httpd 8.5

Step 3: Nmap Scanning Screenshot



Impact:

- HTTP traffic is unencrypted and can be intercepted by malicious actors, potentially leading to man-in-the-middle attacks and exposure of sensitive data.
- Open ports can be exploited by attackers to gain unauthorized access to the web server.

Mitigation Steps:

- Update Microsoft IIS to the most recent stable version to receive the latest security patches.
- Redirect all HTTP traffic (port 80) to HTTPS (port 443) to ensure data encryption.
- Implement logging and monitoring systems to quickly identify and respond to unauthorized access attempts.
- Conduct regular security audits and vulnerability scans to identify and address potential issues.

Resources Used: Kali Linux operating system, Nmap (Network Mapper), Ping command-line tool.

4.2 Task 2 - Directory Brute Forcing

Brute force the website <http://testasp.vulnweb.com/> and find the directories present in the website.

Attack Name: Directory Brute Forcing

Severity: High - CVSS Score 7.0 to 8.9

Reason:

The severity is high because exposed directories such as /images, /cgi-bin, and /templates often contain critical configuration files, sensitive data, and administrative interfaces. Unauthorized access to these directories could lead to data breaches, privilege escalation, and full system compromise.

Steps to Reproduce with Screenshots:

Step 1: Target URL Identification

The target URL for directory brute forcing was confirmed as: <http://testasp.vulnweb.com/>

Step 2: Directory Scanning Using Gobuster

Gobuster, a Kali Linux command line directory brute forcing tool, was used to scan the target URL for hidden directories. The tool uses a wordlist to systematically guess directory names.

Command used: `gobuster dir -u http://testasp.vulnweb.com/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt`

Scan Results:

Directory	Status Code	Size (bytes)
/images	301 (Redirect)	157
/cgi-bin	301 (Redirect)	158
/templates	301 (Redirect)	160
/html	301 (Redirect)	155
/avatars	301 (Redirect)	157

Step 3: Gobuster Scanning Screenshot

[Fig 2: Gobuster scanning result showing discovered directories]

Impact:

- Directories could contain configuration files, login credentials, or proprietary data, potentially resulting in data breaches or unauthorized access.

- These directories may contain files that can be targeted by attackers to gain further access or execute malicious code.
- Identifying and exploiting these directories can interrupt the website's regular functioning, leading to downtime.

Mitigation Steps:

- Restrict access to sensitive directories by implementing strong authentication and authorization measures.
- Regularly review and update configuration files, removing default or unnecessary files that could be exploited.
- Encrypt sensitive data stored in these directories to protect it from unauthorized access.
- Implement comprehensive monitoring and logging to detect and respond to unauthorized access attempts.
- Set appropriate file permissions to limit access to critical files.

Resources Used: Kali Linux operating system, Gobuster directory brute forcing tool.

4.3 Task 3 - Network Traffic Interception

Make a login and intercept network traffic using Wireshark to find credentials transferred through the network.

Attack Name: Network Sniffing / Credential Interception

Severity: High - CVSS Score 7.0 to 8.9

Reason:

Network sniffing is highly severe because it can reveal sensitive information such as passwords and personal data in plaintext. Since the target website uses unencrypted HTTP, login credentials are transmitted without encryption and can be captured by anyone monitoring the network traffic.

Steps to Reproduce with Screenshots:

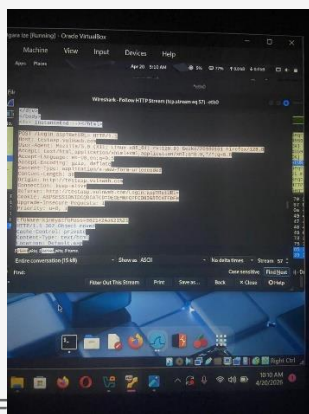
Step 1: Launching Wireshark

Wireshark was launched in the Kali Linux environment. The eth0 network interface was selected to begin capturing all network packets, allowing real-time monitoring and recording of all network traffic.

Step 2: Registering and Logging In

With Wireshark actively capturing packets, Firefox was opened and navigated to the target website's registration page at <http://testasp.vulnweb.com/Register.asp>. A new account was created with custom credentials. After successful registration, the login page was accessed at <http://testasp.vulnweb.com/Login.asp> and credentials were entered to simulate a real-world login attempt.

Username: Kimmy



[Figure 3: Login attempt on the target website]

Step 3: Stopping Capture and Filtering Packets

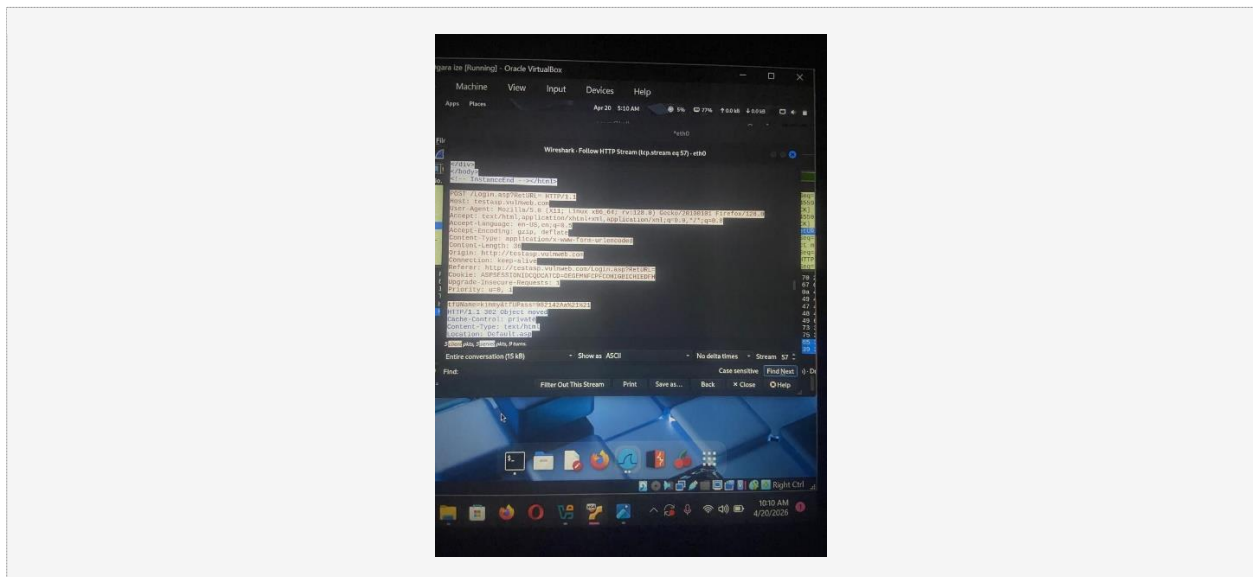
After completing the login, the Wireshark packet capture was stopped. The captured packets were filtered using the following display filter to isolate HTTP POST requests:

Filter: http.request.method == "POST"

The POST request to Login.asp was identified. Using the Follow > HTTP Stream feature, the exact form data transmitted during login was revealed, showing the username and password fields in plaintext.

Results Found:

- ftUName = Kimmy
- ftUPass = [REDACTED - password visible in HTTP stream]



Impact:

- Login credentials exposed in network traffic allow unauthorized individuals to easily intercept and gain access to user accounts.
- Attackers could misuse captured credentials to commit financial fraud or access sensitive data.
- Exposing login credentials puts user privacy at risk by giving attackers access to personal information.

Mitigation Steps:

- Implement HTTPS (SSL/TLS) across the entire website to ensure all communications are encrypted.
- Add Multi-Factor Authentication (MFA) to protect accounts even if credentials are compromised.
- Monitor network traffic using Intrusion Detection Systems (IDS) to identify unusual activities.
- Keep all systems and applications up to date with the latest security patches.

Resources Used: Kali Linux operating system, Wireshark packet analyzer, Firefox web browser.

TASK LEVEL (INTERMEDIATE)

5.1 Intermediate Task 1 - VeraCrypt Hash Decryption

Decrypt a VeraCrypt encrypted file using a hash-encoded password and find the secret code.

Attack Name: Hash Decoding and Disk Encryption Analysis

Severity: High

Reason:

Encrypted files may contain highly sensitive information. Understanding how to decode hash-encoded passwords is a critical skill in cybersecurity for both offensive and defensive operations. Weak hashing algorithms like MD5 can be easily cracked using online tools, exposing sensitive data.

Steps to Reproduce with Screenshots:

Step 1: Retrieve the Encoded Password

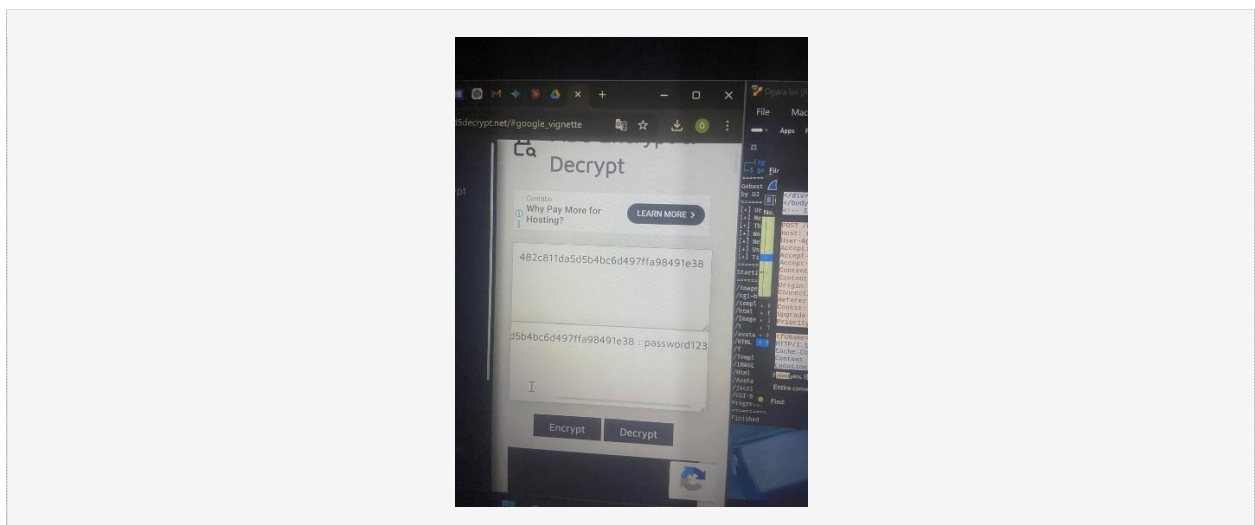
Downloaded the encoded.txt file from the internship drive. The file contained the following MD5 hash:

482c811da5d5b4bc6d497ffa98491e38

Step 2: Decode the MD5 Hash

Used the online MD5 decryption tool at <https://md5decrypt.net> to decode the hash. The tool successfully identified the password.

Decoded Password: password123

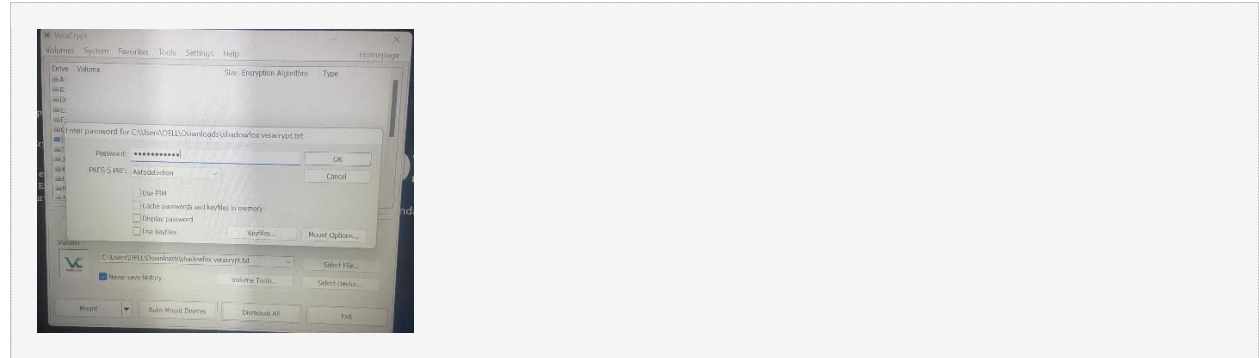


Step 3: Install and Open VeraCrypt

Installed VeraCrypt on Windows 11 using the provided setup file. Launched VeraCrypt and used 'Select File' to locate the shadowfox veracrypt file downloaded from the internship drive.

Step 4: Mount the Encrypted Volume

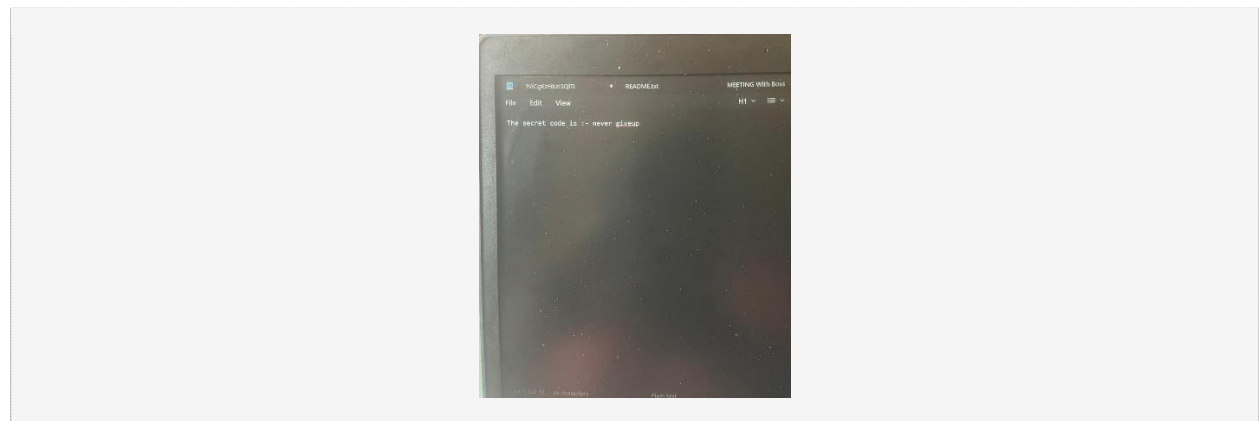
Selected the VeraCrypt encrypted file, clicked 'Mount', and entered the decoded password 'password123'. VeraCrypt successfully decrypted and mounted the volume.



Step 5: Find the Secret Code

Opened the mounted VeraCrypt volume and found the secret code inside the encrypted file.

Secret Code: never give up



Impact:

- Weak or easily guessable hash passwords can be cracked quickly using online tools, exposing sensitive encrypted data.
- MD5 is considered a weak hashing algorithm and should not be used for password storage in modern applications.

Mitigation Steps:

- Use stronger hashing algorithms such as bcrypt, SHA-256, or Argon2 instead of MD5 for password storage.
- Always use strong, complex passwords that are not easily guessable or crackable through dictionary attacks.
- Implement salting when hashing passwords to prevent rainbow table attacks.

Resources Used: Windows 11, VeraCrypt disk encryption tool, MD5Decrypt.net online tool.

5.2 Intermediate Task 2 - PE Executable Entry Point Analysis

Find the address of the entry point of the VeraCrypt executable using PEventool.

Attack Name: Executable Analysis / Reverse Engineering

Severity: Medium

Reason:

Understanding the entry point of an executable is a fundamental skill in malware analysis and reverse engineering. It allows security researchers to identify where program execution begins and analyze potential threats embedded within executables.

Steps to Reproduce with Screenshots:

Step 1: Install PEventool

Downloaded PEventool (version 0.9.9) from <http://wjradburn.com/software/> and extracted it. Note: PE Explorer was initially attempted but does not support 64-bit executables, so PEventool was used as an alternative.

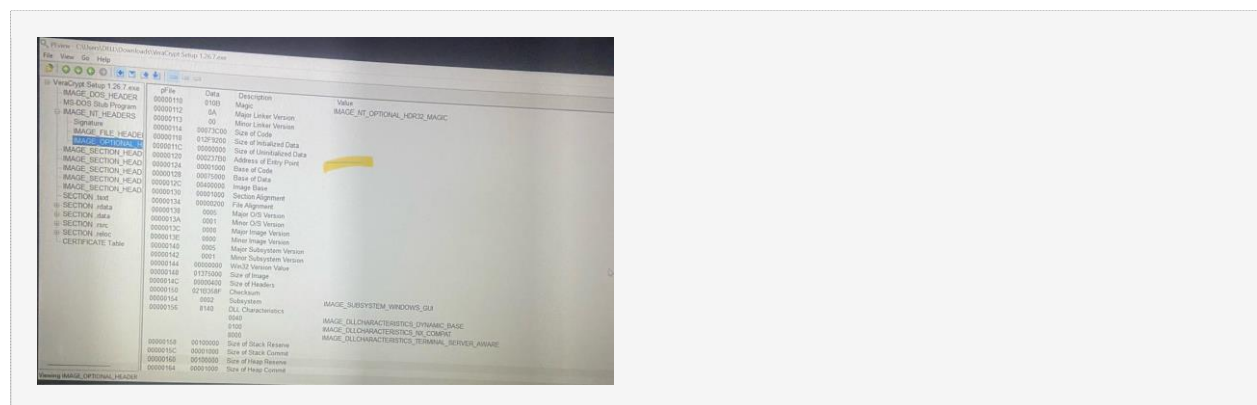
Step 2: Open VeraCrypt Executable in PEventool

Launched PEventool and used File > Open to navigate to and open the VeraCrypt Setup 1.26.7.exe file located in the Downloads folder.

Step 3: Locate the Entry Point

In PEventool, navigated to IMAGE_NT_HEADERS > IMAGE_OPTIONAL_HEADER. Located the 'Address of Entry Point' field which shows the entry point address of the executable.

Address of Entry Point: 000237B0



Impact:

- Knowledge of entry points is essential for malware analysts to understand how malicious software begins execution.

- Entry point analysis helps in identifying packed or obfuscated executables that may hide malicious code.

Mitigation Steps:

- Always verify the integrity of executables using hash verification (MD5, SHA-256) before execution.
- Use application whitelisting to prevent unauthorized executables from running on systems.
- Implement endpoint detection and response (EDR) solutions to monitor and analyze executable behavior.

Resources Used: Windows 11, PEview tool, VeraCrypt Setup 1.26.7.exe.

6. Overall Impact and Risk Summary

Task	Attack Type	Severity	Risk Level
Task 1 - Port Scanning	Port Scanning	High (7.0-8.9)	HIGH
Task 2 - Directory Brute Forcing	Directory Enumeration	High (7.0-8.9)	HIGH
Task 3 - Wireshark Credential Capture	Network Sniffing	High (7.0-8.9)	CRITICAL
Int. Task 1 - VeraCrypt Decryption	Hash Cracking	High	HIGH
Int. Task 2 - Entry Point Analysis	Reverse Engineering	Medium	MEDIUM

All tasks revealed significant vulnerabilities. The combination of open unencrypted HTTP ports, exposed directory structure, plaintext credential transmission, weak MD5 hashing, and publicly accessible executable analysis creates a significant attack surface.

7. Recommendations

- Migrate the entire website from HTTP to HTTPS by implementing a valid SSL/TLS certificate - this is the single most impactful security improvement.
- Update Microsoft IIS to the latest stable version and apply all available security patches regularly.
- Implement proper access controls and authentication for all sensitive directories discovered during testing.
- Deploy a Web Application Firewall (WAF) to detect and block malicious scanning and brute force attempts.
- Enable Multi-Factor Authentication (MFA) for all user accounts to reduce the risk of credential-based attacks.
- Replace MD5 hashing with stronger algorithms such as bcrypt, SHA-256, or Argon2 for all password storage.
- Conduct regular penetration testing and security audits to continuously identify and remediate vulnerabilities.

8. Conclusion

This penetration test and security assessment on <http://testasp.vulnweb.com/> revealed several critical and high-severity vulnerabilities that present significant risks to the confidentiality, integrity, and availability of the web application and its users' data. The most critical finding was

the transmission of login credentials in plaintext over HTTP, which directly exposes users to credential theft.

The intermediate tasks further demonstrated important cybersecurity concepts including hash decryption, disk encryption analysis, and executable reverse engineering. Understanding these techniques is fundamental to a career in cybersecurity.

Immediate action is recommended, with the highest priority given to implementing HTTPS encryption across the entire website. By addressing the vulnerabilities identified in this report and following the mitigation steps outlined, the security posture of the application can be significantly improved, protecting both the system and its users from potential cyber threats.

ADVANCED LEVEL

Table of Contents

1. Introduction
2. Scope and Objectives
3. Tools Used
4. Task 1 - Port Scanning
5. Task 2 - Directory Brute Forcing
6. Task 3 - Network Traffic Interception
7. Overall Impact and Risk Summary
8. Recommendations
9. Conclusion

1. Introduction

In the domain of cybersecurity, understanding and detecting vulnerabilities in web applications is critical to protecting systems against potential cyber threats. During this internship at ShadowFox, I was assigned the task of conducting a comprehensive security evaluation on the following target website:

<http://testasp.vulnweb.com/>

This website is an intentionally vulnerable web application built using ASP, designed as a testing environment for security professionals. The purpose of this report is to document the penetration testing process, findings, and recommendations for improving the security posture of the target application.

2. Scope and Objectives

The scope of this penetration test covers the following three primary activities:

- Port Scanning - Identify all open ports and services running on the target web server
- Directory Brute Forcing - Discover hidden directories and files on the target website
- Network Traffic Interception - Capture and analyze login credentials transmitted over the network

The testing was performed in a controlled environment using the Kali Linux operating system within a virtual machine setup. All activities were conducted on an intentionally vulnerable target designated for educational and testing purposes.

3. Tools Used

Tool	Purpose	Platform
Nmap	Network port scanning and service detection	Kali Linux
Gobuster	Directory and file brute forcing	Kali Linux
Wireshark	Network packet capture and analysis	Kali Linux
Firefox Browser	Web browsing and login simulation	Kali Linux
Ping	Target IP address identification	Kali Linux

4. Task 1 - Port Scanning

Attack Name:

Port Scanning

Severity:

High - CVSS Score 7.0 to 8.9

Reason:

The target website was found to be running an unencrypted HTTP service on port 80. This is considered highly severe because HTTP traffic is transmitted in plaintext, making it extremely susceptible to eavesdropping and man-in-the-middle attacks. Sensitive information such as

login credentials, session tokens, and personal data can be intercepted by malicious actors monitoring the network.

Steps to Reproduce

Step 1: Target IP Identification

The website's IP address was identified using the ping command. This served as a precursor to the port scanning process, confirming that the target was reachable and resolving the domain to its IP address.

Command used:

```
ping testasp.vulnweb.com
```

Result: Target IP Address resolved to 44.238.29.244

Step 2: Port Scanning Using Nmap

Using Nmap, a powerful network scanning tool, a port scan was conducted on the identified IP address. The -sV flag was used to detect open ports and their associated service versions.

Command used:

```
nmap -sV 44.238.29.244
```

Scan Results:

Port/Protocol	State	Service	Version
80/tcp	Open	HTTP	Microsoft IIS httpd 8.5

Port 80 hosts an active HTTP service, indicating a functioning web server powered by Microsoft IIS version 8.5. This server version may contain known vulnerabilities and should be patched to the most recent stable release.

Impact:

- HTTP traffic is unencrypted and can be intercepted by malicious actors, potentially leading to man-in-the-middle attacks and exposure of sensitive data.
- Open ports can be exploited by attackers to gain unauthorized access to the web server.

Mitigation Steps:

1. Update Microsoft IIS to the most recent stable version to receive the latest security patches.
2. Redirect all HTTP traffic (port 80) to HTTPS (port 443) to ensure data encryption and protect against eavesdropping.

3. Implement logging and monitoring systems to quickly identify and respond to unauthorized access attempts.
4. Conduct regular security audits and vulnerability scans to identify and address potential issues.

Resources Used:

Kali Linux operating system, Nmap (Network Mapper), Ping command-line tool.

5. Task 2 - Directory Brute Forcing

Attack Name:

Directory Brute Forcing

Severity:

High - CVSS Score 7.0 to 8.9

Reason:

The severity is high because exposed directories such as /admin, /images, /cgi-bin, and /templates often contain critical configuration files, sensitive data, and administrative interfaces. Unauthorized access to these directories could lead to data breaches, privilege escalation, and full system compromise.

Steps to Reproduce

Step 1: Target URL Identification

The target URL for directory brute forcing was confirmed as: <http://testasp.vulnweb.com/>

Step 2: Directory Scanning Using Gobuster

Gobuster, a Kali Linux command-line directory brute forcing tool, was used to scan the target URL for hidden directories. The tool uses a wordlist to systematically guess directory names.

Command used:

```
gobuster dir -u http://testasp.vulnweb.com/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
```

Scan Results:

Directory	Status Code	Size (bytes)
/images	301 (Redirect)	157

/cgi-bin	301 (Redirect)	158
/templates	301 (Redirect)	160
/html	301 (Redirect)	155
/avatars	301 (Redirect)	157

The scan successfully identified multiple directories on the target website. The /cgi-bin directory can contain executable scripts, and /templates may expose application structure and sensitive configuration information.

Impact:

- Directories such as these could contain configuration files, login credentials, or proprietary data, potentially resulting in data breaches or unauthorized access.
- These directories may contain files that can be targeted by attackers to gain further access or execute malicious code.
- Identifying and exploiting these directories can interrupt the website's regular functioning, potentially leading to downtime or performance degradation.

Mitigation Steps:

5. Restrict access to sensitive directories by implementing strong authentication and authorization measures.
6. Regularly review and update configuration files, removing default or unnecessary files that could be exploited.
7. Encrypt sensitive data stored in these directories to protect it from unauthorized access.
8. Implement comprehensive monitoring and logging to detect and respond to unauthorized access attempts.
9. Set appropriate file permissions to limit access to critical files and ensure sensitive files are not publicly accessible.

Resources Used:

Kali Linux operating system, Gobuster directory brute forcing tool.

6. Task 3 - Network Traffic Interception

Attack Name:

Network Sniffing / Credential Interception

Severity:

High - CVSS Score 7.0 to 8.9

Reason:

Network sniffing is highly severe because it can reveal sensitive information such as passwords and personal data in plaintext. Since the target website uses unencrypted HTTP, login credentials are transmitted without encryption and can be captured by anyone monitoring the network traffic, leading to unauthorized account access, data theft, and privacy violations.

Steps to Reproduce

Step 1: Launching Wireshark

Wireshark was launched in the Kali Linux environment. The eth0 network interface was selected to begin capturing all network packets traveling through the interface, allowing real-time monitoring and recording of all network traffic.

Command used:

wireshark

Step 2: Registering and Logging In

With Wireshark actively capturing packets, Firefox was opened and navigated to the target website's registration page. A new account was created with custom credentials. After successful registration, the login page was accessed and credentials were entered to simulate a real-world login attempt.

Login URL:

<http://testasp.vulnweb.com/Login.asp>

Step 3: Stopping the Capture and Filtering Packets

After completing the login, the Wireshark packet capture was stopped. The captured packets were filtered using the following display filter to isolate HTTP POST requests:

`http.request.method == "POST"`

The POST request to Login.asp was identified. Using the Follow HTTP Stream feature, the exact form data transmitted during the login attempt was revealed, showing the username and password fields in plaintext within the HTTP request body.

Analysis:

The Wireshark capture clearly demonstrated that the target website transmits login credentials in plaintext over HTTP. The form data was visible in the following format:

`tfUName=[username]&tfUPass=[password]`

This confirms a critical vulnerability: any attacker positioned to monitor network traffic can capture valid user credentials without any special effort, confirming a man-in-the-middle attack vector.

Impact:

- If login credentials are exposed in network traffic, unauthorized individuals could easily intercept and use them to gain access to user accounts.
- If the credentials are linked to accounts with financial information, attackers could misuse them to commit financial fraud, including unauthorized transactions.
- Attackers can use captured credentials to log into user accounts, potentially leading to data theft and misuse of personal information.
- Exposing login credentials puts user privacy at risk by giving attackers access to personal information and sensitive data.

Mitigation Steps:

10. Implement HTTPS (SSL/TLS) across the entire website to ensure all communications between client and server are encrypted, preventing credential exposure in transit.
11. Add Multi-Factor Authentication (MFA) to protect accounts even if credentials are compromised.
12. Consistently monitor network traffic using Intrusion Detection Systems (IDS) to identify unusual activities or unauthorized access attempts.
13. Keep all systems, software, and applications up to date with the latest security patches to prevent exploitation of known vulnerabilities.
14. Limit access to sensitive directories and data exclusively to authorized personnel by implementing strong authentication and authorization controls.

Resources Used:

Kali Linux operating system, Wireshark packet analyzer, Firefox web browser.

7. Overall Impact and Risk Summary

Task	Attack Type	Severity	Risk Level
Task 1 - Port Scanning	Port Scanning	High (7.0-8.9)	HIGH
Task 2 - Directory Brute Forcing	Directory Enumeration	High (7.0-8.9)	HIGH

Task 3 - Wireshark Credential Capture	Network Sniffing	High (7.0-8.9)	CRITICAL
---------------------------------------	------------------	----------------	----------

All three tasks revealed high-severity vulnerabilities on the target website. The combination of open unencrypted HTTP ports, exposed directory structure, and plaintext credential transmission creates a significant attack surface that could be exploited by malicious actors to gain unauthorized access, steal sensitive data, or disrupt service operations.

8. Recommendations

- Migrate the entire website from HTTP to HTTPS by obtaining and implementing a valid SSL/TLS certificate. This is the single most impactful security improvement.
- Update the Microsoft IIS web server to the latest stable version and apply all available security patches regularly.
 - Implement proper access controls and authentication for all sensitive directories discovered during testing.
- Deploy a Web Application Firewall (WAF) to detect and block malicious scanning and brute force attempts.
- Enable Multi-Factor Authentication for all user accounts to reduce the risk of credential-based attacks.
- Conduct regular penetration testing and security audits to continuously identify and remediate vulnerabilities.
- Implement comprehensive logging and alerting systems to detect and respond to security incidents in real-time.

9. Conclusion

This penetration test on <http://testasp.vulnweb.com/> revealed several critical and high severity vulnerabilities that present significant risks to the confidentiality, integrity, and availability of the web application and its users' data. The most critical finding was the transmission of login credentials in plaintext over HTTP, which directly exposes users to credential theft.

The directory brute forcing exercise demonstrated that the website's structure is easily discoverable, potentially exposing sensitive files and administrative interfaces. The port scan confirmed the presence of an unencrypted HTTP service running on an outdated version of Microsoft IIS.

Immediate action is recommended, with the highest priority given to implementing HTTPS encryption across the entire website. By addressing the vulnerabilities identified in this report and following the mitigation steps outlined, the security posture of the application can be significantly improved, protecting both the system and its users from potential cyber threats.

END OF REPORT

